

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 01

Domain II - Information Security Risk Management

30 Questions	48 Minutes	Single Best Answer Format
------------------------	----------------------	-------------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 48 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM1-028)

Which statement **BEST** describes risk tolerance?

- A. The acceptable variation around objectives or risk limits for a specific exposure
- B. The maximum aggregate loss the organization could absorb without becoming nonviable
- C. The amount and type of risk the organization is willing to pursue or retain overall
- D. The risk remaining after selected controls have been implemented

Question 2 (CISM1-029)

Which description provides the **MOST** useful foundation for analyzing an information security risk scenario?

- A. A list of vulnerabilities ranked by technical severity
- B. A threat event exploiting a condition and causing business impact.
- C. An inventory of security controls mapped to policy clauses
- D. A forecast of annual security spending by control category

Question 3 (CISM1-030)

Scenario: A regional hospital is assessing a clinical scheduling platform. The application inventory labels it medium criticality, but interviews reveal that emergency departments use its interfaces to locate specialized staff and beds. No single technology manager understands the full workflow.

What should the information security manager do **FIRST** to establish an appropriate impact rating?

- A. Adopt the inventory rating because it is the approved system of record
- B. Increase the rating based on the sensitivity of patient data alone
- C. Use the platform vendor's availability classification
- D. Facilitate a business impact and dependency review with process and data owners

Question 4 (CISM1-031)

Scenario: A financial cooperative has moved customer authentication, analytics, backups, and call-center workflows to different services. Each service passed an individual supplier review, but all four rely on the same underlying cloud region and identity provider.

Which assessment finding is MOST important to communicate to decision-makers?

- A. Each supplier's control report has a different reporting period
- B. Cloud services may cost more than internally hosted services
- C. A shared dependency could create correlated failures across critical processes
- D. The identity provider uses a different risk-rating scale

Question 5 (CISM1-032)

Scenario: A manufacturer must compare cyber risk across twelve plants. Reliable loss-event data is unavailable, plant experts can estimate frequency bands, and executives want consistent prioritization rather than a precise financial forecast.

Which assessment approach is MOST appropriate?

- A. A calibrated semi-quantitative model using defined likelihood and impact ranges
- B. A fully quantitative model that assigns single-dollar loss estimates
- C. An unstructured workshop that records only high, medium, or low opinions
- D. A vulnerability count that treats every plant asset equally

Question 6 (CISM1-033)

Scenario: A retailer requires quarterly reviews of privileged access. The review control is well designed, but evidence shows that two quarters were skipped because responsibility changed during a reorganization. No unauthorized activity has been found.

How should this condition be characterized in the risk assessment?

- A. As proof that privileged access has already caused a loss
- B. As an inherent vulnerability unrelated to the current control environment
- C. An operating control deficiency increasing the chance that misuse goes undetected.
- D. As acceptable residual risk because no misuse was detected

Question 7 (CISM1-034)

What is the primary purpose of estimating both inherent and residual risk?

- A. To guarantee that every control has a measurable financial return
- B. Exposure before controls and exposure remaining under current controls.
- C. To replace business judgment with a standardized score
- D. To demonstrate that compliance requirements eliminate relevant risk

Question 8 (CISM1-035)

Scenario: A logistics company estimates that a warehouse system outage would affect 40% of a \$500,000 asset value per event. Historical and scenario data support an annual rate of occurrence of 0.25. Management uses annualized loss expectancy as one input to treatment decisions.

What is the annualized loss expectancy for this scenario?

- A. \$20,000
- B. \$40,000
- C. \$200,000
- D. \$50,000

Question 9 (CISM1-036)

Scenario: A media company approved an internal generative-technology assistant based on a pilot using public content. The business now plans to connect it to confidential contracts and allow an external provider to retain interaction logs for service improvement.

What should be the information security manager's FIRST risk-assessment action?

- A. Carry forward the pilot's residual-risk rating because the application has not changed
- B. Update risk scenarios and data flows for the new uses and dependencies.
- C. Block the deployment until all emerging-technology risks can be eliminated
- D. Assess only whether the provider has a current assurance report

Question 10 (CISM1-037)

Scenario: Two assessment teams rate the same credential-theft scenario differently. One team interprets likelihood as threat activity, while the other estimates the chance of material business loss after considering controls.

What is the BEST way to resolve the inconsistency?

- A. Restate the likelihood definition, assessment stage, and evidence requirements, then reassess
- B. Average the two ratings to avoid favoring either team
- C. Use the higher rating because security assessments should be conservative
- D. Replace likelihood with the number of recorded vulnerabilities

Question 11 (CISM1-038)

Scenario: A university rates the residual risk of a research-data service as low because a new monitoring control is expected to be operational next month. The current assessment will be presented to a funding committee today.

How should the information security manager record the assessment?

- A. Rate current residual risk as low without qualification because funding is approved
- B. Exclude the scenario until the monitoring control is operational
- C. Treat the planned control as evidence that inherent risk has decreased
- D. Assess residual risk using current controls and document the target state separately.

Question 12 (CISM1-039)

Scenario: An online education provider identifies two high-rated risks. One could interrupt enrollment during a two-week annual peak and threatens a revenue objective; the other could cause similar annualized loss but affects a service scheduled for retirement in three months. Both ratings have comparable confidence.

Which recommendation BEST supports prioritization?

- A. Treat both risks identically because their ratings are equal
- B. Prioritize the retiring service because older technology always creates greater risk
- C. Prioritize the enrollment exposure while validating short-term safeguards for the retiring service
- D. Delay both decisions until precise loss values are available

Question 13 (CISM1-040)

When presenting a quantitative cyber-risk estimate based on limited loss data, what is MOST important to include?

- A. A single exact value so leaders can compare it directly with the budget
- B. A range of outcomes, key assumptions, and sensitivity to variable inputs
- C. Only the worst possible outcome to ensure conservative decisions
- D. The technical vulnerability scores from which the estimate was derived

Question 14 (CISM1-041)

Scenario: A payroll processor notifies a client that it will subcontract tax-document generation. The subcontractor will receive employee identifiers and operate from a jurisdiction not considered in the original assessment. The primary processor remains contractually responsible.

Which factor should drive reassessment MOST directly?

- A. The changed data flow, jurisdiction, dependency, and control environment
- B. Whether the primary processor offers a price reduction
- C. Whether the subcontractor uses the same technology platform
- D. The number of years the primary processor has served the client

Question 15 (CISM1-042)

Scenario: A diversified services group has eight business units. Each rates dependence on the central identity service as medium because its individual financial impact falls within local tolerance. Group-level analysis shows that a single identity outage would halt six units simultaneously and exceed enterprise risk appetite.

What is the MOST appropriate conclusion?

- A. Retain the medium ratings because local tolerance determines enterprise exposure
- B. Raise every unrelated technology risk to high for consistency
- C. Report the aggregated concentration scenario and its enterprise-level impact separately
- D. Remove the local entries because only enterprise risks belong in a risk register

Question 16 (CISM1-043)

Which action is an example of risk avoidance?

- A. Purchasing insurance for costs arising from a data breach
- B. Implementing stronger authentication for a customer portal
- C. Formally retaining exposure within approved limits
- D. Discontinuing the business activity that creates the exposure

Question 17 (CISM1-044)

Which allocation of responsibility is MOST appropriate?

- A. The business risk owner decides on residual-risk acceptance, while designated control owners operate assigned controls
- B. The information security manager accepts all information risk and delegates business impacts to control owners
- C. Internal audit owns residual risk because it independently tests controls
- D. A technology supplier owns the organization's risk whenever it operates the relevant service

Question 18 (CISM1-045)

Scenario: A small credit union identifies a fraud risk above tolerance in a new mobile process. Two controls would reduce the risk to the same acceptable level. Control X costs \$180,000 annually and slightly improves customer convenience. Control Y costs \$70,000 annually but adds a brief verification step that remains within the approved customer-experience standard.

Which response should the information security manager recommend?

- A. Control X because security controls should maximize convenience regardless of cost
- B. Control Y; it achieves acceptable risk at lower cost without breaching standards.
- C. Both controls because layered security is always preferable
- D. Risk acceptance because either control would affect the customer process

Question 19 (CISM1-046)

Scenario: A research company discovers that a legacy platform cannot meet a security obligation imposed by an applicable contract and law. The business owner prefers to accept the risk for another year because replacement would delay a product launch.

What is the BEST course of action for the information security manager?

- A. Record the owner's acceptance and close the issue because the owner controls the budget
- B. Purchase insurance and treat the obligation as transferred
- C. Engage legal and accountable leaders to select and authorize a compliant response.
- D. Allow the launch if technical teams agree to monitor the platform more closely

Question 20 (CISM1-047)

Scenario: A procurement team is about to sign a three-year contract for a platform that will process confidential designs. Security receives the supplier questionnaire after commercial terms have been finalized, leaving no practical leverage to address identified gaps.

Which process change would be MOST effective?

- A. Trigger risk-tiered security review before supplier selection and contract negotiation are completed
- B. Conduct all supplier reviews after contract signature to avoid delaying negotiations
- C. Add a generic right-to-audit clause to every contract without assessing the service
- D. Require security to approve every purchase, regardless of risk

Question 21 (CISM1-048)

Scenario: A utility's approved risk treatment plan defines a trigger: if more than 5% of remote substations miss critical security updates for two consecutive weeks, operations must reassess exposure and consider service restrictions. The metric reaches 7% for a second week because several sites are inaccessible.

What should the information security manager do NEXT?

- A. Declare an incident and disconnect every substation immediately
- B. Wait for evidence of exploitation because the indicator measures potential rather than actual loss
- C. Lower the threshold because inaccessible sites should not count
- D. Invoke the agreed reassessment and response process with the risk owner and operations

Question 22 (CISM1-049)

Scenario: A wholesaler buys cyber insurance covering certain notification and recovery expenses. An executive states that the associated ransomware risk has now been fully transferred.

Which response from the information security manager is MOST accurate?

- A. The statement is accurate because insured events no longer require internal controls
- B. Some financial consequences may be transferred, but operational, reputational, excluded, and accountability exposures remain
- C. Insurance eliminates impact but has no effect on likelihood
- D. Insurance is risk avoidance because the organization no longer bears any loss

Question 23 (CISM1-050)

Scenario: A public transit agency is developing a rider application. A privacy risk above tolerance is identified during design, but the project plan contains no owner, funding, or milestone for treatment. Launch is six months away.

What is the BEST way to integrate the response into the project?

- A. Assign an accountable owner, fund treatment, and require acceptable residual risk before launch.
- B. Wait for prelaunch testing to confirm that the risk exists
- C. Add the risk only to the security team's operational backlog
- D. Transfer the risk to the application development team through the project schedule

Question 24 (CISM1-051)

Scenario: A pharmaceutical laboratory cannot deploy the standard endpoint agent on a validated instrument without invalidating its regulatory certification. The system contains valuable formulas and must remain network connected for a critical process. The owner requests a two-year exception and proposes network isolation plus manual monthly log review.

What should the information security manager do FIRST?

- A. Approve the exception because the standard control is technically incompatible
- B. Reject the exception because standards must apply identically to every asset
- C. Evaluate the compensating controls, then present residual risk to the authorized owner.
- D. Accept the risk on behalf of the laboratory to avoid process interruption

Question 25 (CISM1-052)

Scenario: A division president agrees verbally to retain a moderate data-availability risk that falls within delegated authority. The risk register still lists mitigation as pending, and no review date or assumptions are recorded.

What should the information security manager do NEXT?

- A. Close the risk because verbal acceptance by an authorized executive is sufficient
- B. Obtain documented acceptance that states the scenario, residual exposure, authority, rationale, conditions, and review date
- C. Change the risk rating to low so the register reflects the president's decision
- D. Ask the control owner to sign the acceptance instead of the division president

Question 26 (CISM1-053)

Scenario: A consumer lender mitigates account-takeover risk with transaction monitoring. For four months, alert review times have worsened, false-negative testing has exceeded the approved threshold, and the control owner repeatedly misses corrective milestones. Residual risk is now above tolerance.

Which action is MOST appropriate?

- A. Continue routine reporting until the annual risk review
- B. Transfer risk ownership to the monitoring team because it operates the control
- C. Lower the control-performance target to reflect actual staffing
- D. Escalate the deteriorating control performance and exposure to the accountable risk owner.

Question 27 (CISM1-054)

Scenario: A food distributor is acquiring a smaller company whose order platform has unsupported components and cannot be integrated securely before the transaction closes. The acquired platform is essential for six months, the risk exceeds normal tolerance, and the acquisition authority has approved a temporary higher tolerance with conditions.

Which response is BEST?

- A. Immediately shut down the acquired platform despite the business interruption
- B. Accept the risk indefinitely because acquisition activity is strategically important
- C. Apply time-bound controls, document authorized acceptance, and track migration triggers.
- D. Rely on the seller's prior practices until the next annual assessment

Question 28 (CISM1-055)

Scenario: The board risk committee receives a monthly dashboard listing 140 overdue security tasks and technical severity scores. Members say they cannot tell whether exposure is improving or what decisions they need to make.

How should the information security manager improve the dashboard?

- A. Show material risk scenarios, trends against appetite, treatment effectiveness, exceptions, and decisions required
- B. Rank tasks by the age of each ticket and remove business context
- C. Report only items that have already caused a financial loss
- D. Add more technical findings so the committee has complete detail

Question 29 (CISM1-056)

Scenario: An insurer approved residual risk for a claims service based on internal-only access and daily reconciliation. A change request now proposes public application programming interface access for partners and replaces reconciliation with weekly sampling.

What is the MOST appropriate response?

- A. Wait for monitoring data after deployment before revisiting residual risk
- B. Retain the previous acceptance because the underlying claims service is unchanged
- C. Approve the change if the project manager accepts the schedule risk
- D. Require reassessment because exposure and a key control assumption are changing.

Question 30 (CISM1-057)

Scenario: Separate business units have approved short-term exceptions for the same encryption requirement. Each exception is within local authority, but collectively they cover 62% of customer records, several have been renewed twice, and the aggregate exposure exceeds enterprise appetite.

What should the information security manager recommend?

- A. Leave the exceptions unchanged because each was approved within local authority
- B. Escalate the aggregate exposure and recurring pattern for an enterprise treatment and acceptance decision
- C. Cancel every exception immediately without consulting the business owners
- D. Split the exception records into smaller groups so none exceeds the reporting threshold

Answer Key

Domain II - Information Security Risk Management

1 A	2 B	3 D	4 C	5 A
6 C	7 B	8 D	9 B	10 A
11 D	12 C	13 B	14 A	15 C
16 D	17 A	18 B	19 C	20 A
21 D	22 B	23 A	24 C	25 B
26 D	27 C	28 A	29 D	30 B

Detailed Explanations

Question 1 (CISM1-028)

Correct answer: A - The acceptable variation around objectives or risk limits for a specific exposure

Risk tolerance translates broader appetite into acceptable boundaries for a particular objective or exposure. Risk capacity is the maximum the organization can absorb, risk appetite expresses the overall amount and type of risk it is willing to pursue or retain, and residual risk is what remains after controls.

Question 2 (CISM1-029)

Correct answer: B - A threat event exploiting a condition and causing business impact.

A useful risk scenario connects a threat event, an exploitable condition, and a business consequence affecting an asset or process. Information about vulnerabilities alone omits threat and impact, a control inventory describes defenses rather than exposure, and a spending forecast does not define a risk event.

Question 3 (CISM1-030)

Correct answer: D - Facilitate a business impact and dependency review with process and data owners

A cross-functional impact and dependency review identifies how the platform supports care delivery and lets accountable business and data owners validate criticality. The inventory may be outdated, data sensitivity alone does not capture operational impact, and a vendor classification cannot reflect the hospital's unique processes.

Question 4 (CISM1-031)

Correct answer: C - A shared dependency could create correlated failures across critical processes

The shared region and identity provider create concentration risk: one disruption could affect several supposedly separate services and business processes at once. Reporting-period differences may require review, cost is not the principal security finding, and rating-scale differences can be normalized without eliminating the underlying correlated exposure.

Question 5 (CISM1-032)

Correct answer: A - A calibrated semi-quantitative model using defined likelihood and impact ranges

Defined frequency and impact ranges provide consistency while acknowledging limited data, making a semi-quantitative approach suitable for prioritization. Point-value financial estimates would imply unsupported precision, an unstructured workshop would reduce comparability, and vulnerability counts do not represent business risk.

Question 6 (CISM1-033)

Correct answer: C - An operating control deficiency increasing the chance that misuse goes undetected.

The control exists and is appropriately designed, but it did not operate as intended, so the missed reviews are an operating deficiency that affects likelihood and detection. They do not prove a loss, they are part of the current control environment rather than inherent exposure, and absence of detected misuse is not evidence that the residual risk is acceptable.

Question 7 (CISM1-034)

Correct answer: B - Exposure before controls and exposure remaining under current controls.

Comparing inherent and residual risk shows the exposure without controls and what remains after considering current controls, supporting treatment decisions. It does not guarantee a financial return, eliminate the need for judgment, or establish that compliance removes business risk.

Question 8 (CISM1-035)**Correct answer: D - \$50,000**

The single loss expectancy is \$500,000 multiplied by the 40% exposure factor, or \$200,000. Multiplying that amount by the annual rate of occurrence of 0.25 gives an annualized loss expectancy of \$50,000. The other values omit or misapply one of these factors, and the estimate should remain one input rather than a claim of certainty.

Question 9 (CISM1-036)**Correct answer: B - Update risk scenarios and data flows for the new uses and dependencies.**

The changed data classification, external retention, and use purpose alter the exposure and require updated scenarios and data flows. The pilot rating rests on invalid assumptions, eliminating all risk is unrealistic and bypasses business decision-making, and a provider report alone cannot assess the company's specific data-use risks.

Question 10 (CISM1-037)**Correct answer: A - Restate the likelihood definition, assessment stage, and evidence requirements, then reassess**

The teams are measuring different concepts, so the manager should align definitions, clarify whether controls are considered, specify evidence, and reassess. Averaging incompatible ratings has no sound meaning, automatically choosing the higher rating introduces bias, and vulnerability counts are not a substitute for likelihood.

Question 11 (CISM1-038)**Correct answer: D - Assess residual risk using current controls and document the target state separately.**

Residual risk should reflect controls currently operating; the expected state after the planned control is implemented is target risk and should be documented separately with assumptions and timing. Counting a future control understates current exposure, excluding the scenario hides a relevant risk, and planned controls do not change inherent risk.

Question 12 (CISM1-039)**Correct answer: C - Prioritize the enrollment exposure while validating short-term safeguards for the retiring service**

The enrollment exposure is time-sensitive and directly threatens a current business objective, while the retirement horizon may justify limited interim safeguards for the other risk. Equal scores do not erase differences in timing and strategic context, technology age alone is not decisive, and waiting for false precision could miss the peak period.

Question 13 (CISM1-040)**Correct answer: B - A range of outcomes, key assumptions, and sensitivity to variable inputs**

Ranges, assumptions, and sensitivity show decision-makers how input variability affects the estimate and prevent false precision. A single exact value can mislead, the worst case alone does not represent the distribution of plausible outcomes, and technical scores do not by themselves explain the estimate's limitations.

Question 14 (CISM1-041)**Correct answer: A - The changed data flow, jurisdiction, dependency, and control environment**

The new recipient, jurisdiction, dependency, and control environment materially change the scenario and may affect likelihood, impact, and obligations. Price and relationship duration do not determine exposure, while a shared platform is only one technical detail and would not address the full change in risk context.

Question 15 (CISM1-042)

Correct answer: C - Report the aggregated concentration scenario and its enterprise-level impact separately

Aggregation reveals an enterprise concentration risk that local assessments obscure, so it should be reported as a distinct scenario while preserving useful local records. Local tolerance does not override enterprise appetite, unrelated risks should not be inflated, and deleting local entries would remove ownership and context.

Question 16 (CISM1-043)

Correct answer: D - Discontinuing the business activity that creates the exposure

Avoidance removes the activity or condition that gives rise to the risk. Insurance transfers or shares certain financial consequences, stronger authentication mitigates likelihood, and formal retention within authority is risk acceptance.

Question 17 (CISM1-044)

Correct answer: A - The business risk owner decides on residual-risk acceptance, while designated control owners operate assigned controls

The accountable business risk owner makes acceptance decisions within delegated authority, while control owners are responsible for operating their controls. Security facilitates and advises rather than accepting all business risk, internal audit must remain independent, and outsourcing service operation does not transfer the organization's accountability.

Question 18 (CISM1-045)

Correct answer: B - Control Y; it achieves acceptable risk at lower cost without breaching standards.

Control Y meets the defined risk and customer-experience criteria at materially lower cost, so it provides the better business-aligned treatment. Control X offers little additional risk benefit, deploying both is not justified by the scenario, and acceptance is inappropriate while the exposure is above tolerance and a proportionate treatment exists.

Question 19 (CISM1-046)

Correct answer: C - Engage legal and accountable leaders to select and authorize a compliant response.

A business owner generally cannot accept noncompliance where a binding obligation removes that discretion. Legal and accountable leadership should determine a compliant treatment, with escalation if action is not authorized. Insurance does not erase legal duties, monitoring may not satisfy the obligation, and budget control alone does not grant acceptance authority.

Question 20 (CISM1-047)

Correct answer: A - Trigger risk-tiered security review before supplier selection and contract negotiation are completed

An early, risk-tiered review preserves options to select another supplier, require controls, price treatment, or obtain authorized acceptance before commitment. Universal security approval is inefficient, post-signature review is too late to influence terms, and a generic clause alone may neither address specific risks nor be usable in practice.

Question 21 (CISM1-048)

Correct answer: D - Invoke the agreed reassessment and response process with the risk owner and operations

The approved trigger has been met, so the manager should initiate the predefined reassessment and bring the risk owner and operations into the response decision. Waiting defeats the purpose of a leading indicator, retroactively changing the threshold undermines governance, and declaring an incident or disconnecting all sites is not supported by the stated condition.

Question 22 (CISM1-049)

Correct answer: B - Some financial consequences may be transferred, but operational, reputational, excluded, and accountability exposures remain

Insurance can share specified financial losses, but it does not remove disruption, reputational harm, exclusions, duties, or management accountability. Controls may still be required, impact is not eliminated, and avoidance would require discontinuing the risk-producing activity rather than financing part of a loss.

Question 23 (CISM1-050)

Correct answer: A - Assign an accountable owner, fund treatment, and require acceptable residual risk before launch.

An owned and funded treatment plan tied to a project gate makes the risk decision part of delivery governance before options narrow. A security backlog lacks business accountability, waiting until testing is unnecessarily late, and assigning work to developers does not transfer risk ownership or acceptance authority.

Question 24 (CISM1-051)

Correct answer: C - Evaluate the compensating controls, then present residual risk to the authorized owner.

The proposed controls must be evaluated against the actual threat scenarios, dependencies, and monitoring needs before the authorized owner decides whether the remaining exposure and exception period are acceptable. Incompatibility alone does not justify approval, rigid rejection ignores valid compensating approaches, and the security manager should not accept business risk for the laboratory.

Question 25 (CISM1-052)

Correct answer: B - Obtain documented acceptance that states the scenario, residual exposure, authority, rationale, conditions, and review date

Formal documentation creates traceability and clarifies what was accepted, by whom, under which assumptions, and for how long. Verbal agreement is difficult to evidence, acceptance does not change the assessed risk level, and a control owner is not automatically authorized to accept the business exposure.

Question 26 (CISM1-053)

Correct answer: D - Escalate the deteriorating control performance and exposure to the accountable risk owner.

Sustained threshold breaches and missed treatment milestones have pushed exposure above tolerance, requiring timely escalation to the accountable risk owner for a new decision. Annual reporting is too late, changing targets to match poor performance conceals the exposure, and operating a control does not make the monitoring team the business risk owner.

Question 27 (CISM1-054)

Correct answer: C - Apply time-bound controls, document authorized acceptance, and track migration triggers.

A temporary, authorized exception supported by compensating controls, explicit conditions, monitoring, and a migration deadline aligns the approved business transition with risk discipline. Immediate shutdown disregards the authorized objective, indefinite acceptance exceeds the decision's scope, and relying on prior practices provides neither assessed controls nor active monitoring.

Question 28 (CISM1-055)

Correct answer: A - Show material risk scenarios, trends against appetite, treatment effectiveness, exceptions, and decisions required

Board-level reporting should connect material scenarios and trends to risk appetite, show whether treatments work, identify exceptions, and state decisions or escalations needed. More technical detail and ticket age do not establish business significance, while reporting only realized losses omits forward-looking risk oversight.

Question 29 (CISM1-056)

Correct answer: D - Require reassessment because exposure and a key control assumption are changing.

External access changes the threat surface and reduced reconciliation changes the control environment, invalidating central assumptions of the prior acceptance. The service name remaining the same is irrelevant, a project manager's schedule authority does not establish risk-acceptance authority, and postdeployment review would expose the organization before a decision is made.

Question 30 (CISM1-057)

Correct answer: B - Escalate the aggregate exposure and recurring pattern for an enterprise treatment and acceptance decision

Individually authorized exceptions can create a systemic exposure that exceeds enterprise appetite, so leadership with enterprise authority must consider a coordinated treatment and acceptance decision. Local approvals do not resolve aggregate risk, unilateral cancellation may disrupt business without an authorized plan, and dividing records would conceal rather than manage the exposure.